🌐 Module 05: Web Application Penetration Testing

```
# Exercise 16: Exploiting IDOR Vulnerability
```

Scenario

Insecure Direct Object Reference (IDOR) occurs when an application provides direct access to internal objects or resources (such as files, user IDs, database records, or transaction pricing) based on user-supplied input without performing proper authorization checks on the server side.

When client-side applications pass sensitive parameters—such as ticket prices or user IDs—directly in request parameters (GET/POST), attackers can manipulate these parameters using interception proxies like Burp Suite to alter transaction amounts or view unauthorized data.

In this exercise, we use Burp Suite Proxy against the **bWAPP** `Insecure DOR (Order Tickets)` module to tamper with the ticket price parameter, purchasing event tickets for 0 Euros instead of the default rate of **15 Euros** per ticket.

Objective

The objective of this lab is to help students learn how to:
- Intercept HTTP GET/POST requests using Burp Suite Proxy
- Identify client-side trust vulnerabilities and unvalidated object references (`ticket_price`)
- Perform parameter tampering to bypass application authorization and pricing controls

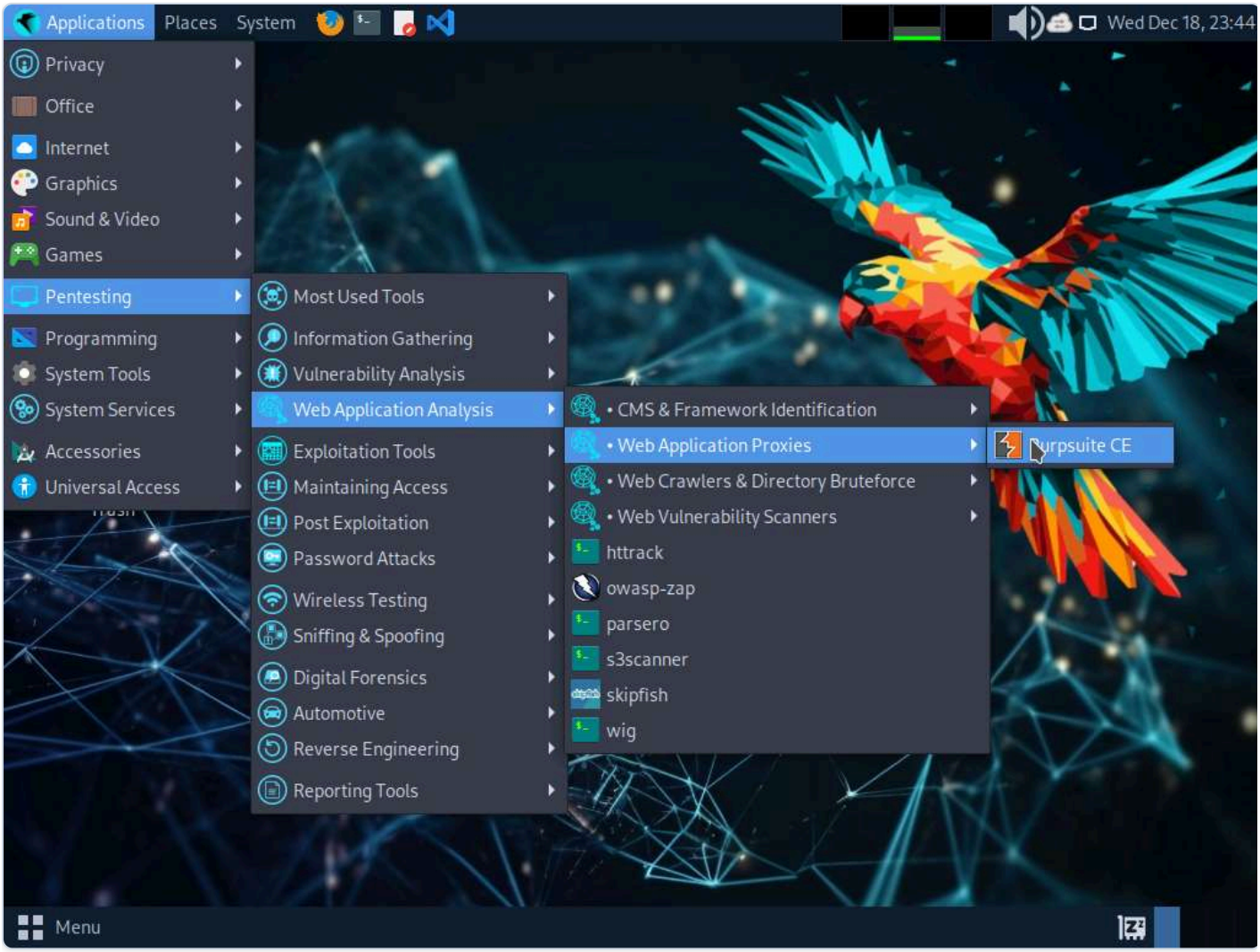
---

Task 1: Exploiting IDOR Vulnerability

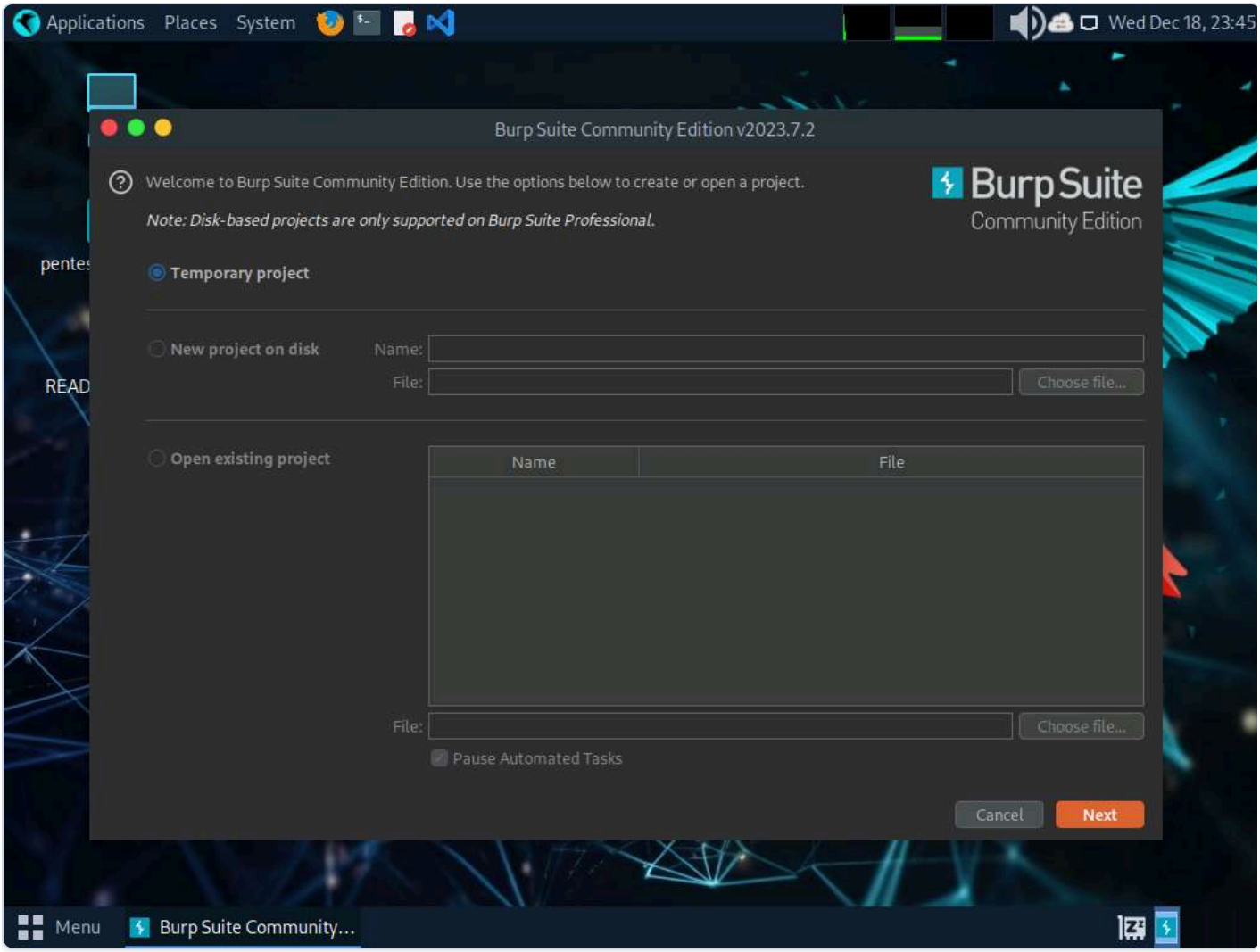
In this task, we launch Burp Suite Community Edition on Parrot Security, capture ticket purchase requests from bWAPP (`http://192.168.0.19`), inspect client-side parameters, alter the ticket price parameter from 15 Euros to 0 Euros, and confirm ticket order fulfillment without payment.

Lab Tasks

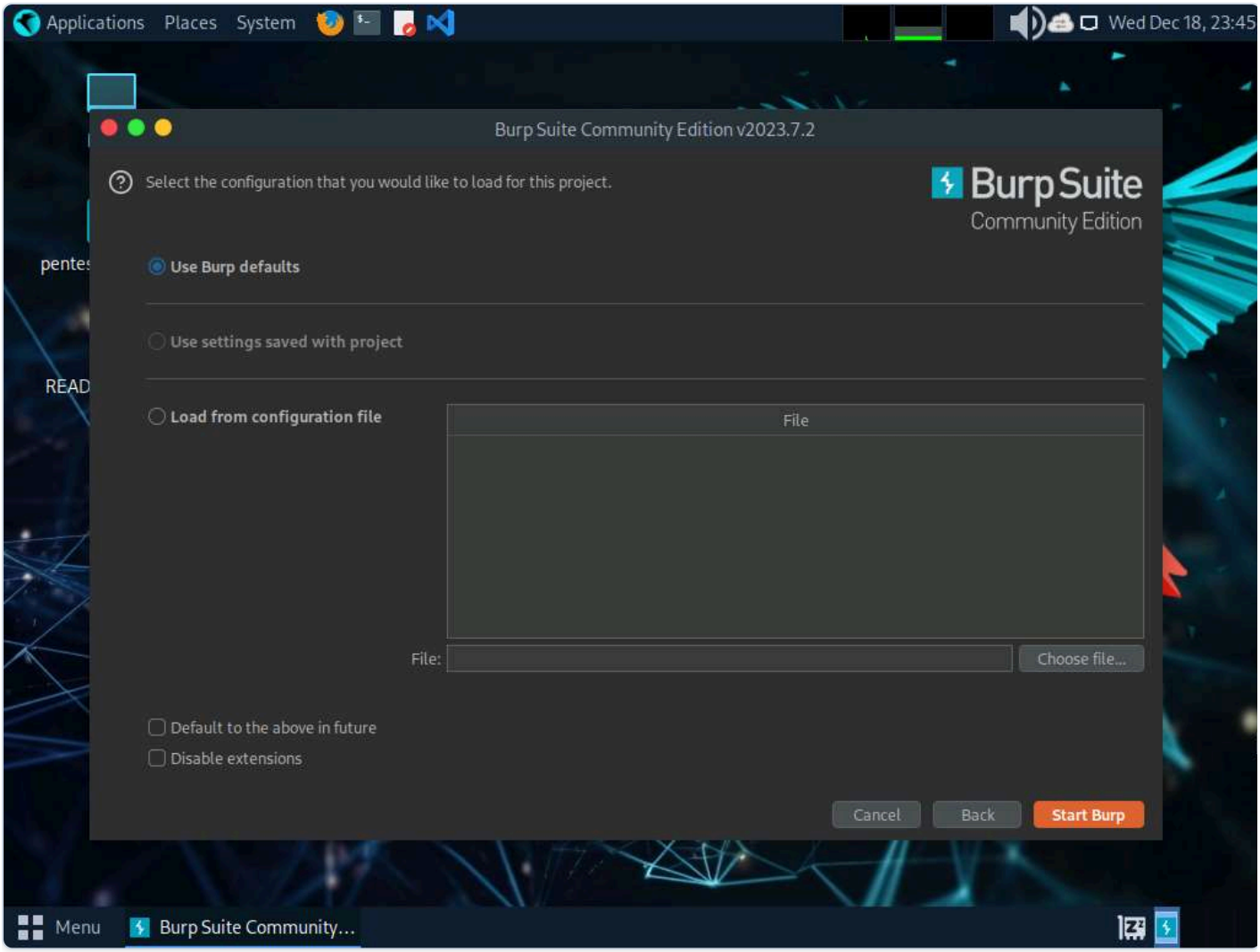
1. Ensure bWAPP is running on the Ubuntu host (`docker run -d -p 80:80 raesene/bwapp`).
2. In the **Parrot Security** machine, launch Burp Suite from **Applications** --> **Pentesting** --> **Web Application Analysis** --> **Web Application Proxies** --> **Burpsuite CE**.
3. Click **OK** on terms, then click **I Accept**.



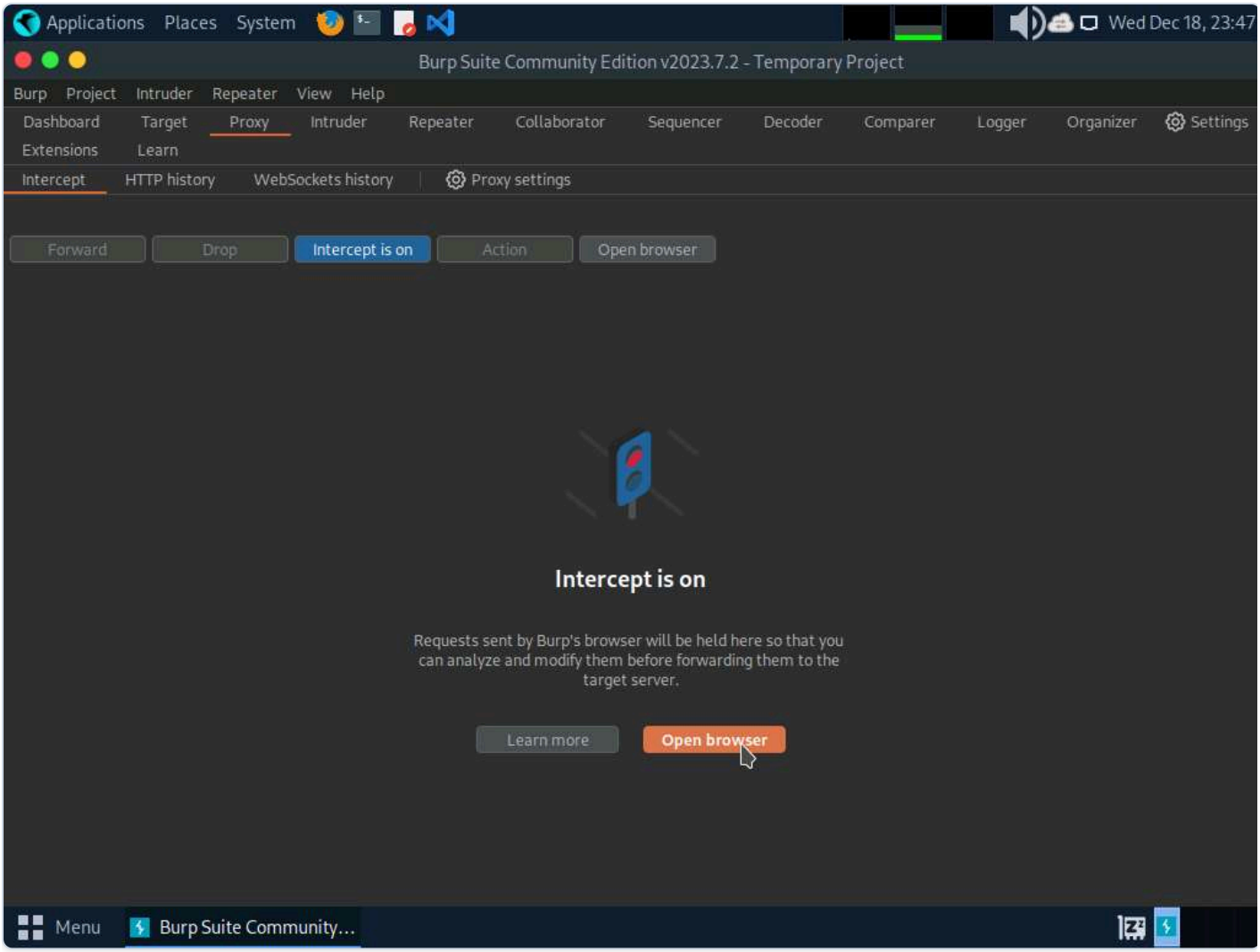
1. Select **Temporary project** and click **Next**.



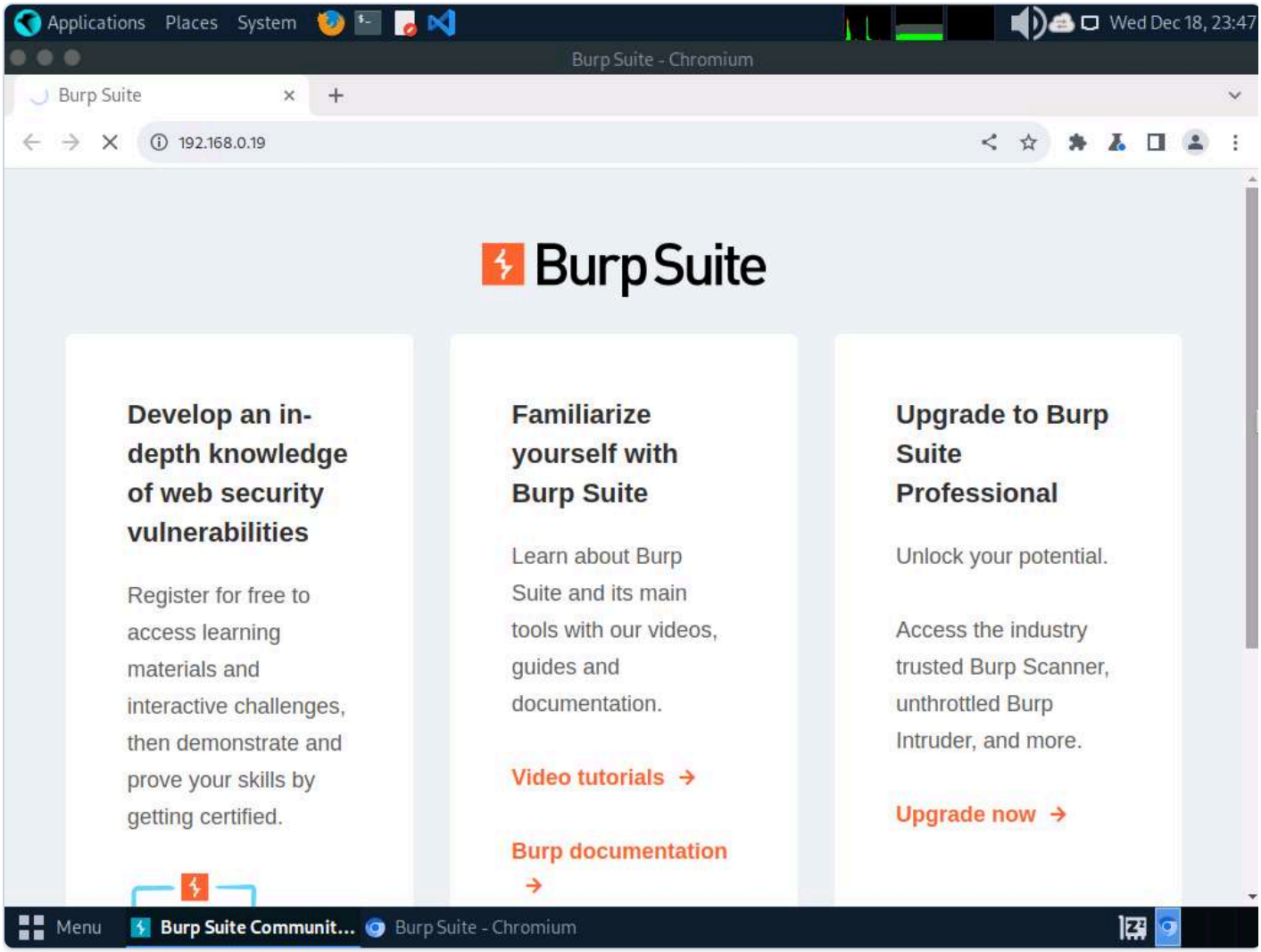
1. Select **Use Burp defaults** and click **Start Burp**.



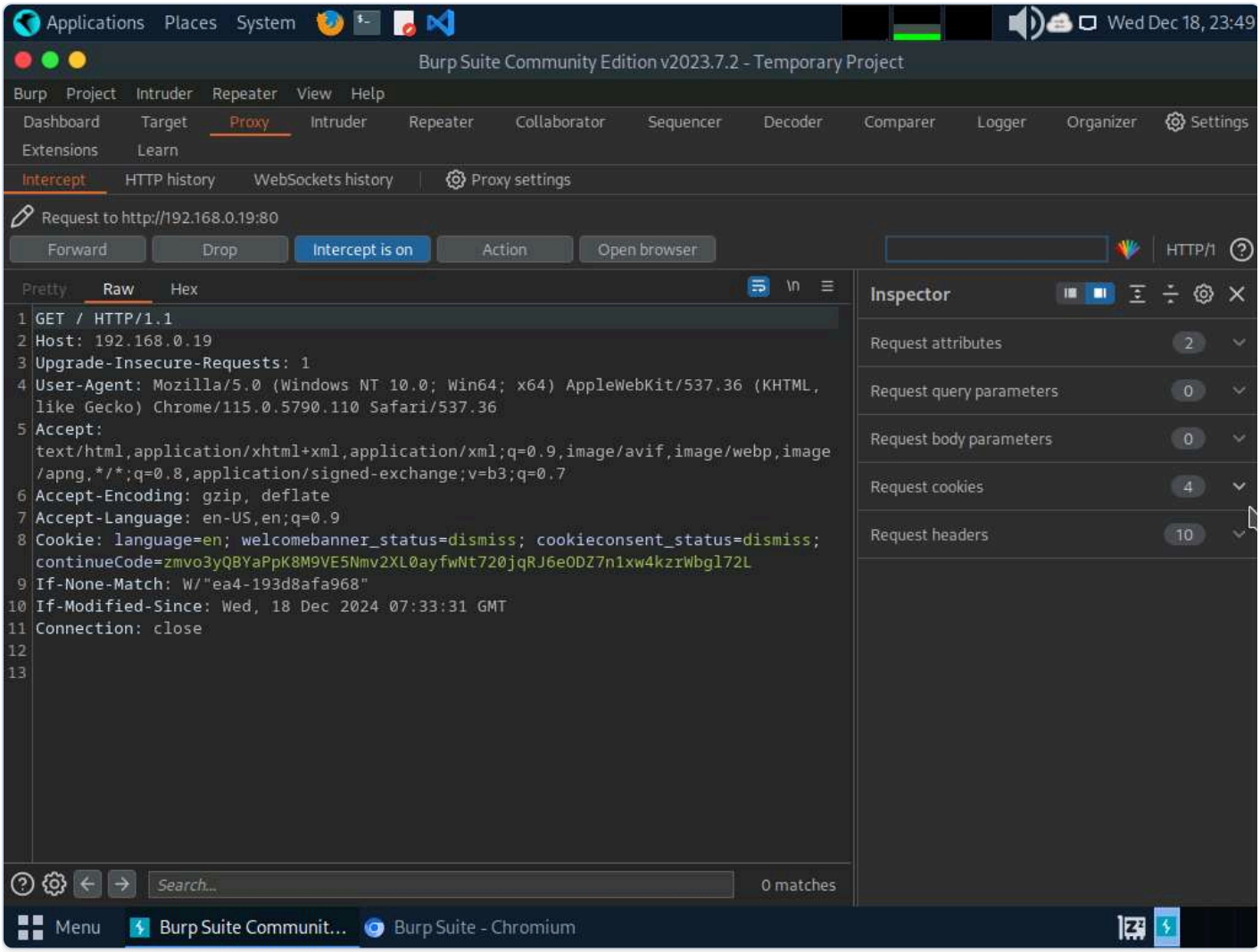
1. Navigate to the **Proxy** tab and click **Open browser** to launch Burp's embedded Chromium browser.



1. In Burp's browser, navigate to **http://192.168.0.19**.



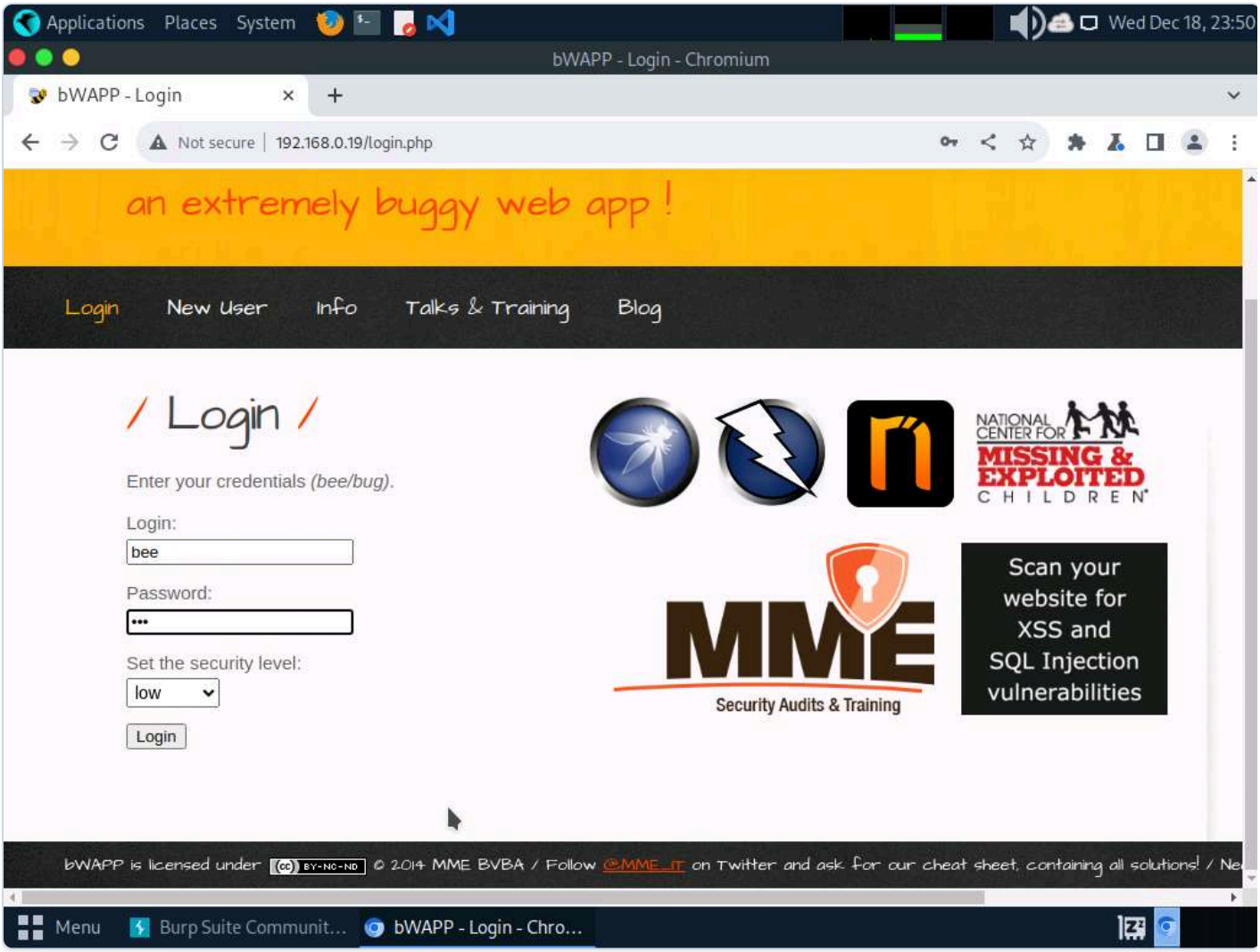
1. Switch to Burp Suite's **Intercept** tab to verify that the HTTP request is captured.



1. Click **Forward** continuously until the bWAPP login page renders in the browser.



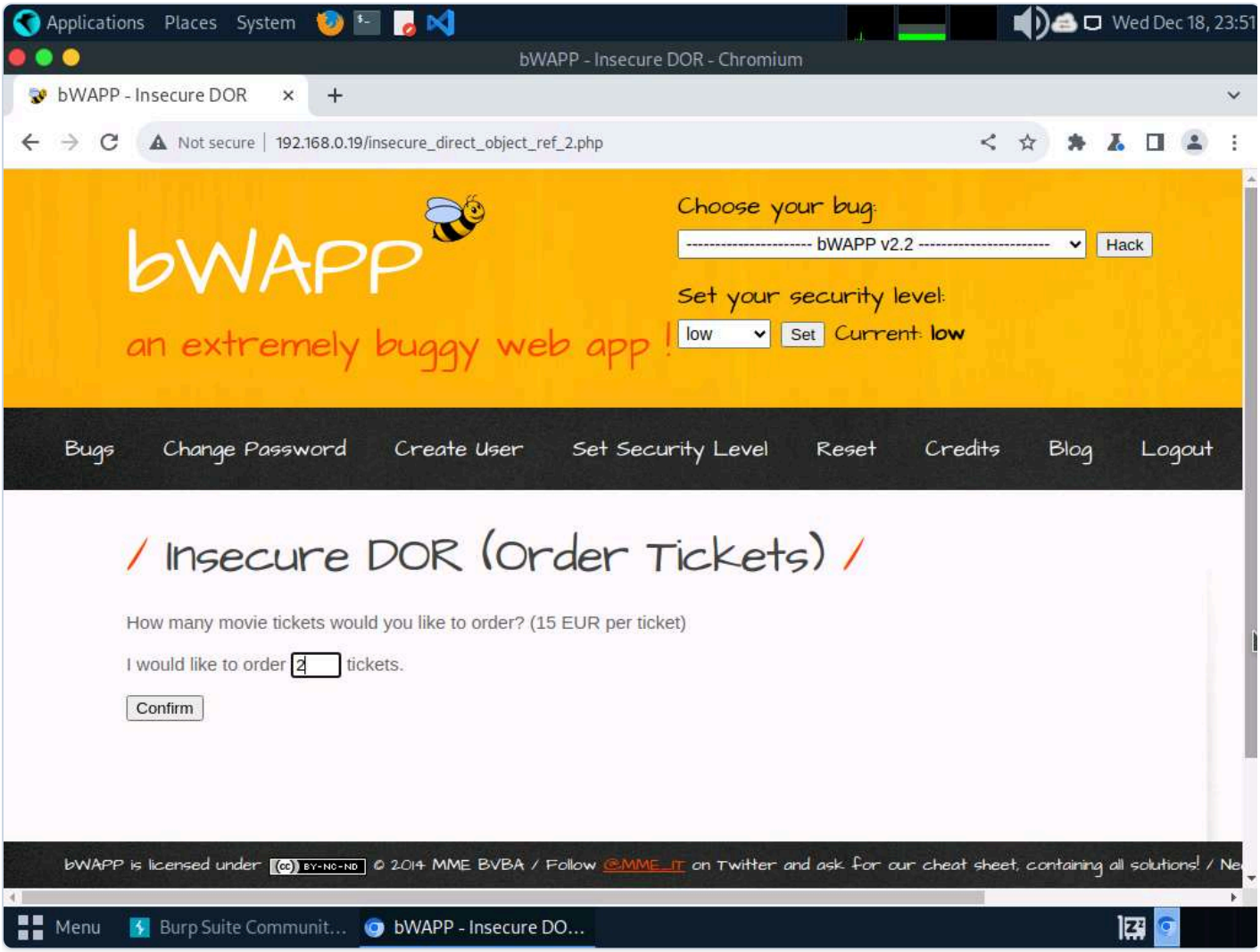
1. Log into bWAPP using **bee** / **bug**, forwarding all intercepted requests in Burp.



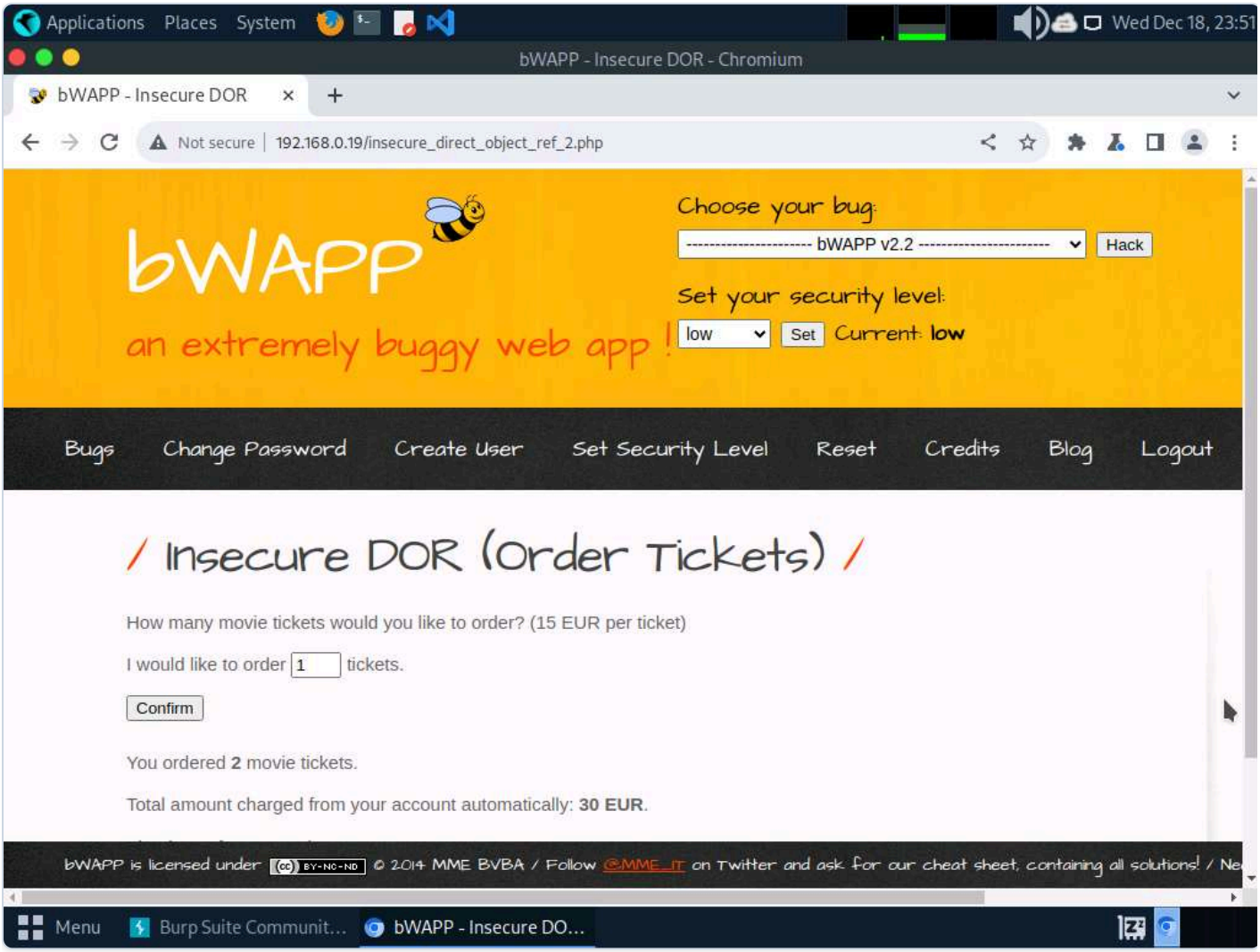
1. Under **Choose your bug**, select **Insecure DOR (Order Tickets)** and click **Hack**. Forward the request in Burp.



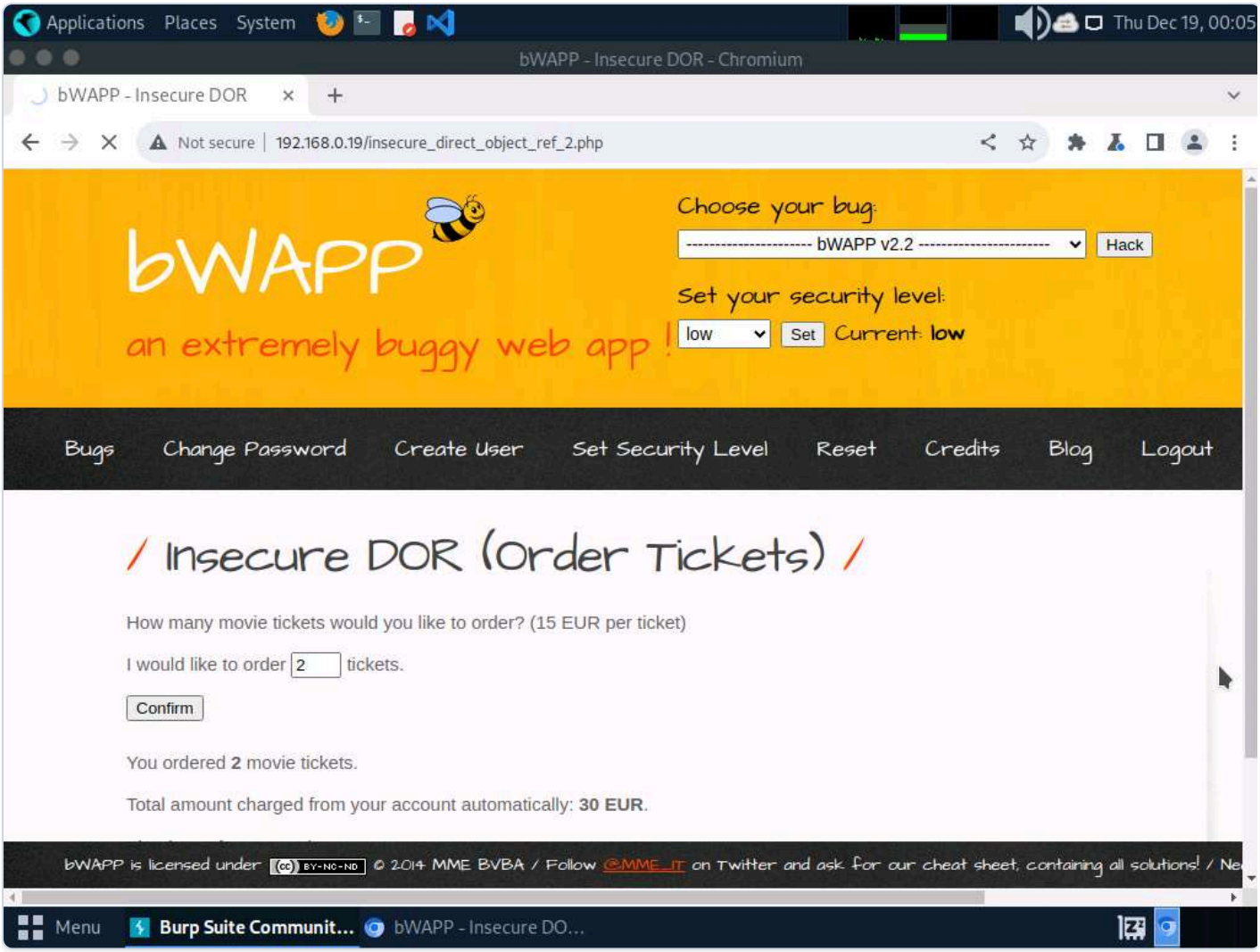
1. In the ticket order form, set the number of tickets to **2** and click **Confirm**. Forward the intercepted request.



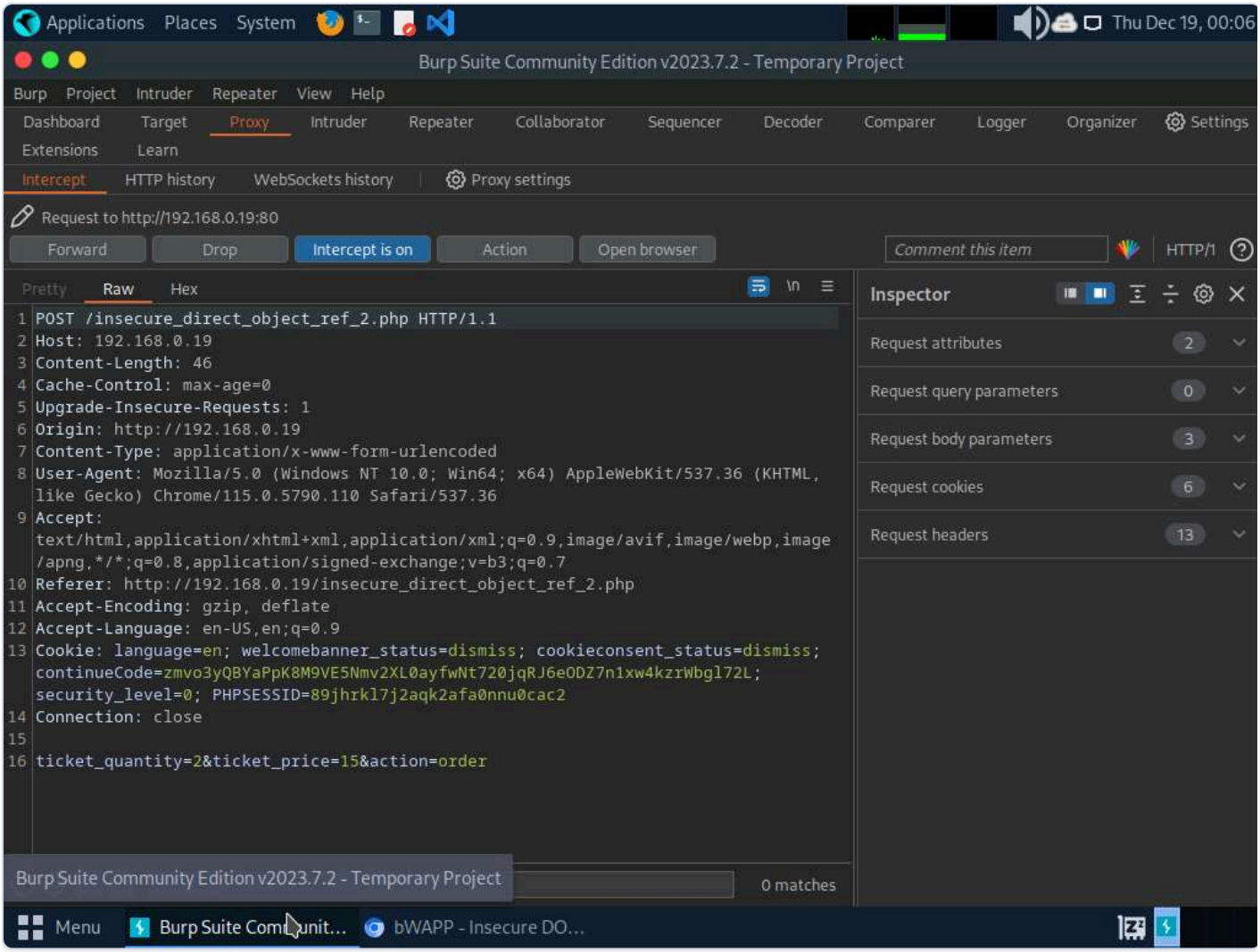
1. Observe the baseline charge: **30 Euros** for 2 tickets, establishing the price per ticket as **15 Euros**.



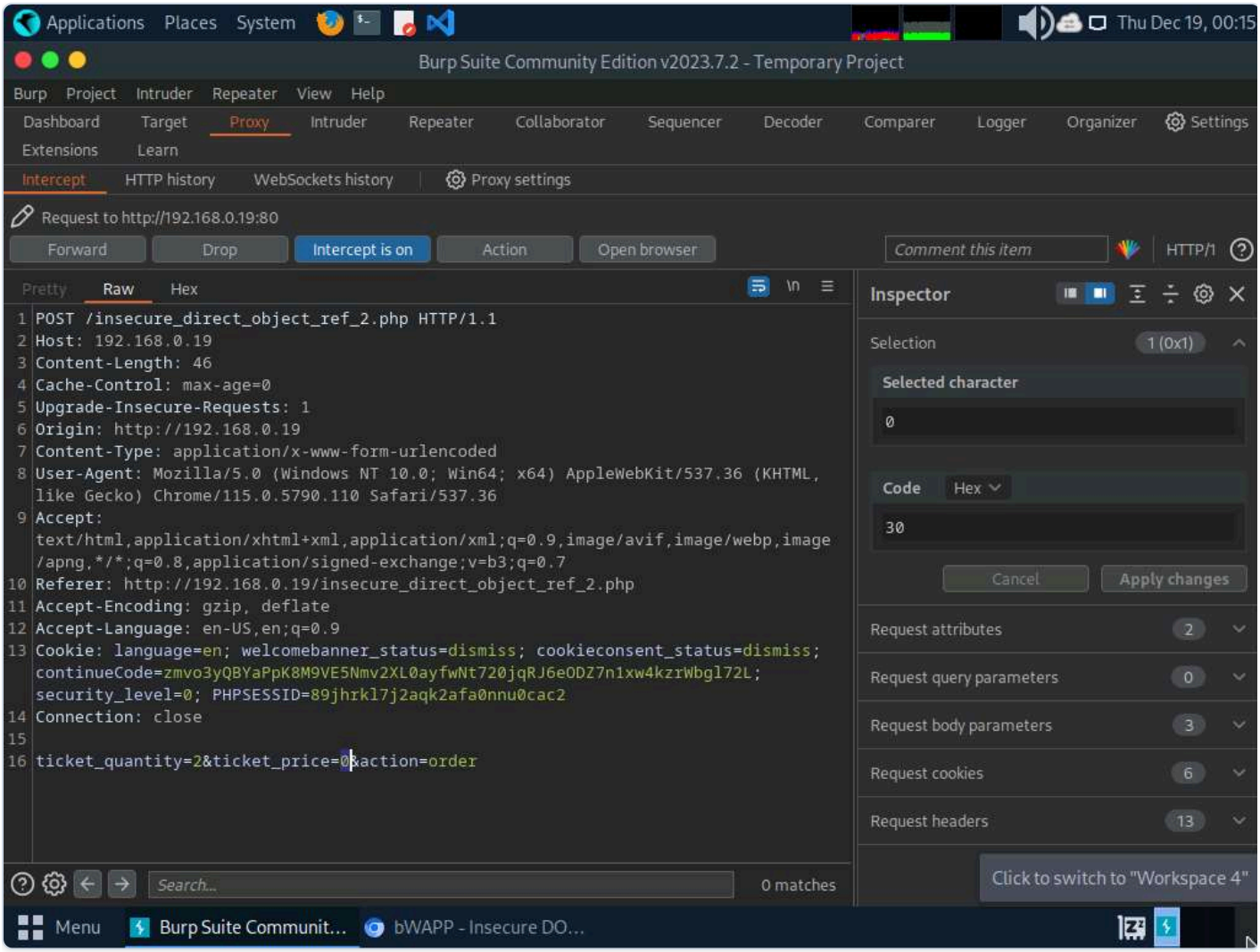
1. Order **2** tickets again and click **Confirm**.



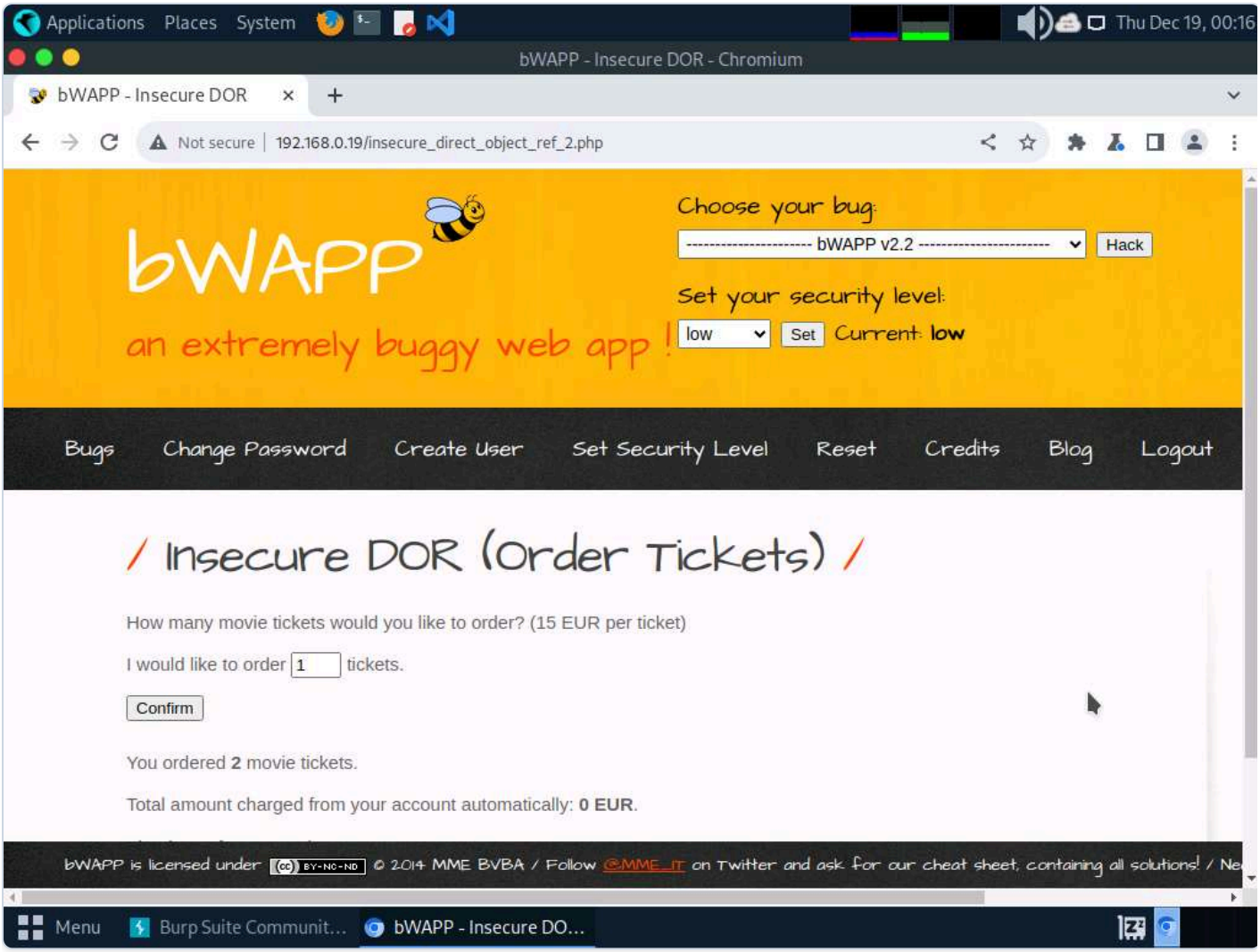
1. Switch to Burp Suite and review the intercepted `GET` request. Observe the client-side price parameter: **ticket_price=15**



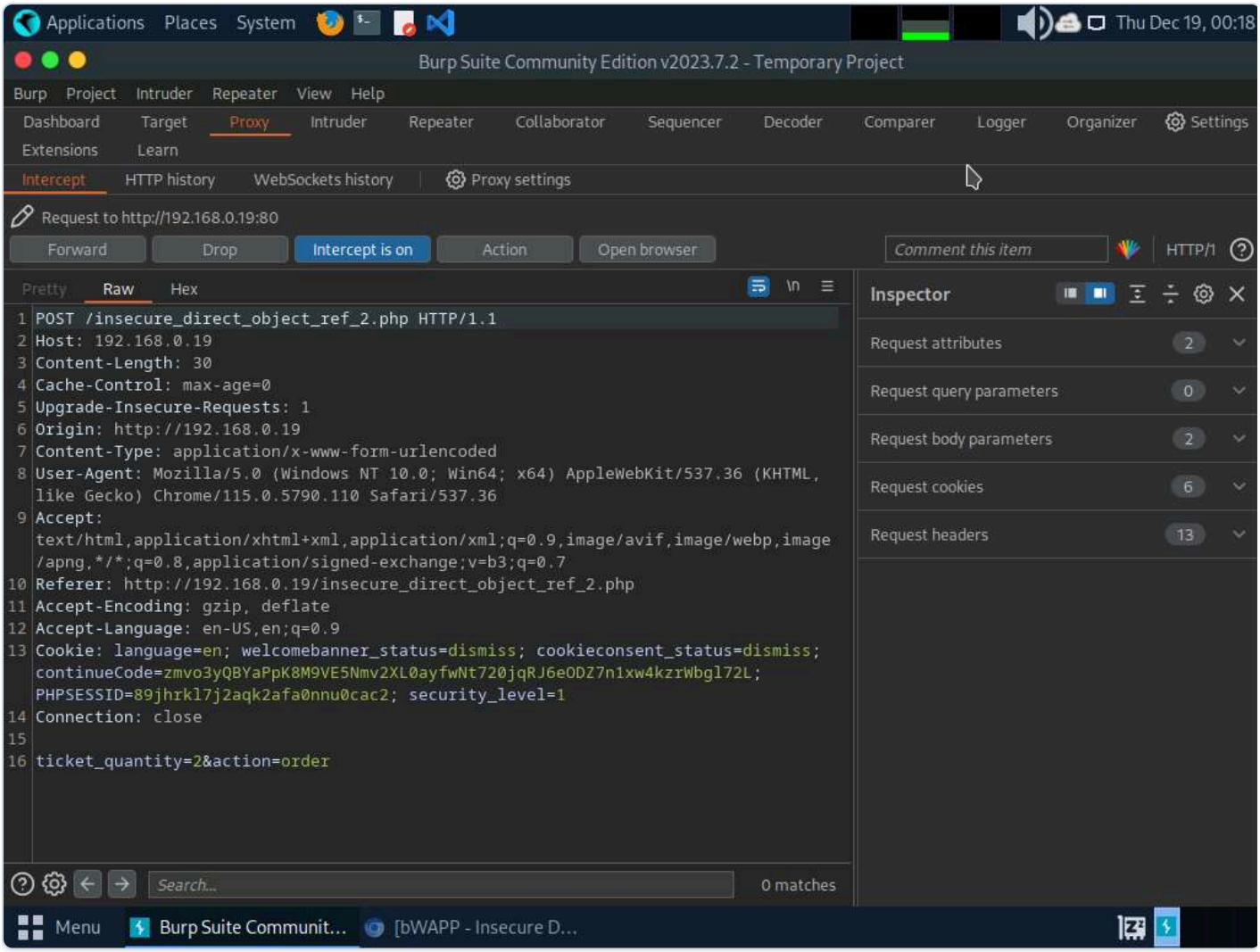
1. Tamper with the parameter value in Burp Intercept, modifying **ticket_price=15** to **ticket_price=0**. Click **Forward**.



1. Inspect the browser response: **2 tickets** are successfully ordered at a total cost of **0 Euros**.



1. Change the bWAPP **Security Level** to **Medium** and click **Set**. Re-attempting ticket ordering under Medium security shows that `ticket_price` is no longer exposed client-side, requiring deeper server-side assessment.



1. Close all open windows on Parrot Security.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.16.1.1** In the Parrot Security environment, utilize Burp Suite to simulate and analyze Insecure Direct Object Reference (IDOR) vulnerabilities in bWAPP. Explore how various user roles can be leveraged to exploit these vulnerabilities, specifically using the "Insecure DOR (Order Tickets)" bug. Input the number of Euros charged per ticket during the testing process. [!SUCCESS] ✅ **Answer:** **15**